

Minimal Sufficient Governance Context: Compiling Loss Models and Reachable Execution Semantics into Cost-Aware Runtime Authority Contracts for Autonomous Agents

Gaston Besanson*

Companion artifact: `sarc-authority-derivation`. Paper 5 of the SARC series, built on the pinned `sarc-suite-one-pass` artifact (arXiv 2608.18360, commit 782261e) as a read-only imported baseline.

Abstract

Given a declared loss model and the states an autonomous system can reach, we derive and certify the minimal, cost-aware sets of runtime observations sufficient to make every modeled safe-versus-unsafe authority distinction. We do not declare an observation set and hope it is complete: we *synthesize* every minimal sufficient contract (a reduct, encoding this artifact’s own discernibility sets – Skowron and Rauszer, 1992 – as CNF for SAT/MaxSAT solvers), certify each one with a machine-checkable partition certificate, and select among them by declared observation cost, not cardinality alone. On a real code/cloud authority domain (not planted for this purpose), the individually-indispensable core is **not sufficient** as a runtime contract (six of ten candidates) and two distinct seven-attribute reducts exist; a preregistered cost model separates them exactly (CH-B2: **supported**, the cheaper contract costs 6.124 against 7.354 for the alternative, both independently certified safety-equivalent). On a second, larger, non-planted domain built independently of this question (thirty-five candidate properties), the same core-is-not-a-reduct distinction recurs (CH-C1: **supported**, a four-property core, minimum reduct cardinality nine, at least five distinct minimum-cardinality contracts) – but the same domain’s own cost model does *not* separate them: CH-C2 is **not supported**, a genuine, fully explained cost tie across every known minimum-cardinality contract at 9.153, reported as found, not reframed. We register and measure discernibility-family scaling on candidate-attribute universes up to one hundred properties, where exhaustive reduct enumeration is expected and confirmed infeasible within a registered three-hundred-second budget, while SAT/MaxSAT synthesis solves in well under a second; MaxSAT showed no measured cardinality advantage over plain SAT on these specific registered families, a two-sided registered question, not a claim tuned toward the outcome we expected. AuthorityBench compares four baselines – a declared-only manual policy, ABAC-mining reimplemented from Xu and Stoller (2015), essential-variable analysis, and exhaustive reduct enumeration – across three domains; the declared-only baseline is not exactly sufficient on any of them. Every synthesized contract is compiled with a sufficiency certificate and, where the reachable set is enumerable, a counterexample when it is not – a runtime gate is meant to consume the certificate, not a claim.

1 Problem

A pre-action authority gate is exactly as complete as whoever declared its observation set thought to be. `sarc-suite-one-pass`’s own imported baseline (`specs/authority.yaml`) observes two things: whether the acting role is on an allow-list, and whether an order value exceeds a single scenario-wide cap – and, on the real code/cloud domain below, a **declared-only policy of this same shape is not exactly sufficient** (a stronger, machine-checked version of

*Universidad Torcuato Di Tella

the same finding this artifact’s own v2 baseline comparison already made, and a finding that also holds on AuthorityBench’s other two registered domains, Section 7). This paper’s claim: given one declared loss model and one executable-reachable action set, *compile* – do not hand-author – the exact, minimal, cost-aware runtime context a gate must observe, with alternative contracts, certificates, and counterexamples a downstream system can consume directly, not merely a number a human reads once.

2 Formal Objects

Let a **reachable state** be one executable-reachable tuple over a declared set of candidate properties. Let a **loss model** M be a finite set of boolean predicates over a reachable tuple, each declaring one way an action can be unsafe. Two reachable tuples are a **cross-verdict pair** if M ’s verdict differs between them.

Definition 1 (Participation, the one-flip criterion). Property p is authority-bearing for M iff there exist executable-reachable tuples a, a' differing only in p – a single flip, holding every other candidate property fixed – whose M -verdicts differ.

Definition 2 (The core P^*). P^* is the set of every property participating by Definition 1.

Definition 3 (The derived coverage list). The candidate properties not in P^* .

Definition 4 (Sufficiency). A property set S is sufficient for M iff any two reachable tuples agreeing on every property in S also agree on their M -verdict. Equivalently (Skowron and Rauszer’s discernibility-matrix device, 1992): for every cross-verdict pair, its *difference set* is the candidate properties on which the pair disagrees, and S is sufficient iff S hits every difference set.

Definition 5 (A reduct). A minimal sufficient set: sufficient, and no proper subset is.

Definition 6 (The core, restated as an intersection). The intersection of every reduct.

This discernibility restatement is what makes reduct synthesis tractable past exhaustive enumeration (Section 6): a difference set that is a proper superset of another already in the family adds no separate hitting-set constraint, and the pruned family becomes one CNF clause per surviving difference set and one boolean variable per candidate property – a SAT or MaxSAT solver’s own input, not the 2^n subset enumeration every backend is still cross-checked against everywhere exhaustion stays affordable.

3 Core versus Reduct

Definition 2’s P^* (individual indispensability, a singleton-perturbation witness) and Definition 5’s reduct (joint sufficiency, Definition 4) are different properties.

Proposition 1’ (replacing the original, corrected Proposition 1). Claim one, Definition 1’s witness search computes exactly the core, Definition 6; claim two, the core is a subset of every reduct; claim three, *if* the core is sufficient, *then* the core is the unique reduct – claim three’s antecedent never assumed, always decided per instance by a sufficiency certificate or a concrete counterexample.

Negative Proposition N (the core need not be sufficient, in general). The registered two-state counterexample (candidate properties $x, y \in \{0, 1\}$, reachable set $\{(x=0, y=0), (x=1, y=1)\}$, verdict $M(x, y) = x$) has an *empty* core – no reachable pair differs in exactly x or exactly y , since the set’s only two members differ in both at once – that is trivially *not sufficient* ($M(0, 0) \neq M(1, 1)$, yet the empty set determines nothing), with $\{x\}$

and $\{y\}$ each an independent singleton reduct, neither equal to the core. This is the sharpest possible instance: a core that is not merely non-maximal but *empty*, directly falsifying the general claim the original Proposition 1 made (Section 11 records the correction itself as a finding, not smoothed over).

The worked introduction: this artifact’s own v2 procurement instance, where claim three’s antecedent holds. This artifact’s registered retail-procurement domain – nine original candidate properties plus `min_order_quantity`, a declared cross-field reachability filter, and two characterized remediation mechanisms – is not a counterexample to Proposition 1’: it is the case where the antecedent fires. CH-A8 certifies the v2 core sufficient over the full reachable set; CH-A10 (exhaustive enumeration of every candidate subset) confirms the core – nine properties – is the **unique reduct**, of minimum cardinality nine. This is this paper’s simplest instance, worked first because it is the one case in this whole artifact where core and reduct coincide – every domain in Section 4 is chosen to test whether that coincidence holds again, and mostly does not.

4 Realistic Evidence: The Empirical Centre

Section 3’s abstract distinction and its one worked coincidence (v2) leave open whether either shape is typical on a domain not designed around the question. Four hypotheses, on two independently-built domains neither planted to exhibit core-versus-reduct or cost separation, are this paper’s own empirical centre.

CH-B1 (a software-and-cloud execution-agent domain). [PROOF-STATUS: MACHINE-CHECKED] (`checkers/ch_b1_check.py`, all candidate subsets of ten candidates considered, subset-pruned). The core (six properties: `approval_token`, `data_classification`, `delegated_role`, `operation`, `repository`, `resource_owner`) is **not sufficient** as a contract – individually indispensable, not jointly enough – and two distinct minimum reducts exist, both of cardinality seven, each the core plus exactly one more property: the core plus `branch`, or the core plus `environment` – two operationally different, equally sufficient ways to close the same coverage gap.

CH-B2 (does a preregistered observation-cost model separate CH-B1’s own two reducts?) [PROOF-STATUS: MACHINE-CHECKED] (`checkers/ch_b2_check.py`). **Supported**, positive strict cost separation: the minimum-cost contract (core plus `branch`, cost 6.124) is strictly cheaper than the other minimum-cardinality reduct (cost 7.354, delta 1.230) – both independently certified safety-equivalent before cost is consulted at all, so cost breaks a tie between two contracts already known interchangeable for safety, not a shortcut around safety.

CH-C1 (does core-versus-reduct recur on a second, independently-built, much larger domain?) A thirty-five-property enterprise access-governance domain – seven properties from each of five families, six reachability drivers, twenty-nine derivation rules – whose reachability and derivation structure were fixed for organisational plausibility *before* any core, reduct, or cost outcome was computed. [PROOF-STATUS: MACHINE-CHECKED] (`checkers/ch_c1_check.py`, 27,000 reachable tuples swept). **Supported**: the core (four properties: `approval_token`, `delegated_role`, `resource_environment`, `workflow_stage`) is **not sufficient**, minimum contract cardinality is nine, and at least five distinct minimum-cardinality contracts exist – a genuine lower bound, via blocking-clause enumeration capped at five, never claimed exhaustive. Exhaustive enumeration was separately attempted, registered budget three hundred seconds, and confirmed infeasible (wall time 300.08s, against 6,724,520 size-seven subsets alone).

CH-C2 (does a preregistered cost model separate CH-C1’s own minimum-cardinality contracts?) [PROOF-STATUS: MACHINE-CHECKED] (`checkers/ch_c2_check.py`, same domain as CH-C1). **Not supported**, a negative tie: every

one of the five known minimum-cardinality contracts costs exactly 9.153 under this domain’s own seven-tier cost model – a genuine, fully explained tie, retained and reported, not reframed. The tied contracts substitute properties from the *same* declared cost tier for one another, so a cost model built at this granularity cannot discriminate between them – weighted optimisation over declared cost is **conditional** on the cost model actually separating the substitute properties in play; CH-B2 shows a domain where it does, CH-C2 shows one where, at the granularity actually declared, it does not.

5 Synthesis: SAT, MaxSAT, and Weighted Contracts

`synthesis.py` encodes Section 2’s discernibility family as CNF and exposes three backends: plain SAT (any sufficient contract, not necessarily minimal), cardinality MaxSAT (a soft unit clause per property, weight one), and weighted MaxSAT (the same construction with each property’s declared observation cost as its own soft-clause weight); a blocking-clause multiplicity method (added for CH-C1) repeatedly re-solves the same objective, excluding each prior model with one added hard clause, stopping as soon as an iteration’s optimum exceeds the first – a genuine lower bound on multiplicity, never 2^n enumeration. Every backend is held to exhaustive reduct enumeration’s own from-first-principles answer everywhere exhaustion is affordable – a real regression would be caught by comparison, not assumed away by trusting a solver.

Cost-aware synthesis’ mechanism was proved first on a small, hand-derived domain before it was asked of a realistic one: a boolean **a** and a bijected pair **b1**, **b2** where minimum cardinality (**{a}**, cost 4.00) and minimum declared cost (**{b1, b2}**, cost 1.00, delta 3.00) disagree by construction – proof the mechanism *can* select a strictly cheaper sufficient contract over a smaller one, not yet evidence a realistic domain does the same. This artifact’s own v1/v2/v4 domains showed no divergence at the time (uniform declared cost floor, every one of their own cost deltas exactly zero) – the operational-value question this left open is exactly what CH-B2 and CH-C2 above now answer, on two realistic domains, in both directions.

6 Scale: Symbolic Synthesis Beyond Exhaustive Search

Three registered scaling results, kept as three separate, still-valid questions, none superseding another.

Exploratory (v5.0, kept, degeneracy disclosed). The original planted-reduct scaling experiment grew the candidate-property count alone ($n = 10, 30, 50, 100$) while deliberately holding the reachable set fixed at six tuples. All exact at every size, wall time between 0.0004s and 0.0005s with no distinguishable growth trend – a real, valid answer to the question it was built for, but a **degenerate** one for scale in general: the noise properties never appear in any discernibility-family clause, costing the solver nothing beyond one extra boolean variable each. Relabelled `exploratory_v5_0` and superseded as the primary scaling claim by the two results below, not deleted.

The tuple-scaling result (v5.1, kept). Holding the candidate-property count small enough to stay exhaustible, a planted two-reduct family grows the reachable set itself to 100,001 tuples: the discernibility family still reduces, after superset removal, to exactly one set, and both planted reducts are recovered exactly by every backend.

The primary scaling table (v5.3): combinatorial hardness. Three families pair a planted minimum-reduct size with a large candidate-attribute universe, far past exhaustive-enumeration tractability, and a diverse discernibility structure:

Family	n	k	Discern. family (pruned)	Exhaustive enumeration
A	30	5	125 sets	infeasible, 300s budget
B	60	10	250 sets	infeasible, 300s budget
C	100	15	375 sets	infeasible, 300s budget

Cardinality- and cost-MaxSAT both found the exact, hand-proved minimum reduct at every family regardless, in well under a second per family – families that are hard for exhaustive enumeration are not automatically hard for the solvers synthesizing over their own discernibility family (Section 10). **Two-sided, reported as measured:** MaxSAT showed no meaningful cardinality advantage over plain SAT on any of these three families – this registration pre-committed to accept and report a uniformly-absent advantage as a legitimate outcome, not a benchmark failure.

7 AuthorityBench

AuthorityBench runs four baselines – manual least-privilege (the declared-only shape), ABAC policy mining (reimplemented from Xu and Stoller, TDSC 2015, independently validated against the published “Health Care Sample Policy” case study before being trusted here), essential-variable analysis, and exhaustive reduct enumeration – across three domains this artifact independently registered (procurement, code/cloud, data-and-communications), six metrics each. The declared-only manual baseline is not exactly sufficient on any of the three – Section 1’s opening claim, measured across every registered domain this artifact has, not asserted from one. Mining agrees with the packaged `derive_authority_contract`’s own minimum-cardinality answer on the procurement and code/cloud-core instances and lands on the *other* known minimum reduct (the `environment` variant of CH-B1’s own two) on the code/cloud domain – both genuine, independently-verified minimum reducts of the identical model, a tie-break divergence between two independently-computed global minima, not a disagreement about which properties matter. Decision: **inconclusive** by the registered rule applied honestly to what was measured – a registered non-result for whether mining tends to be avoidably non-minimal, reported as such rather than reframed as a win.

Two further registered results share this domain portfolio. **The budget-binding scenario (v5.2):** a procurement scenario constructed so the budget loss predicate actually fires – it did, in every one of sixty of sixty cells (137,711 firings total) – and CH-A1’s own derived-zero-miss guarantee held on every one of them. **The isolated-arm re-measurement (v0.4):** direct code inspection found the baseline, derived, and over-inclusive experiment arms sharing one budget and one grant ledger, a real internal-validity threat registered before any fix was written. The isolation hypothesis itself was **not supported:** all thirty registered seeds across both workflows, re-run under the corrected, isolated design, reproduce the prior shared-state result’s own means, confidence intervals, and booleans byte-for-byte – a direct diagnostic confirmed the one loss predicate the bug could have corrupted fired zero times in any cell. The corrected design is kept regardless of the null result.

8 Runtime Implication

`src/authority_compiler` packages this paper’s own machinery behind one call, `derive_authority_contract`, returning a compiled `AuthorityContract`: the core, every reduct where exhaustion is affordable, the minimum-cardinality and minimum-cost reducts, the redundant-attribute list, a sufficiency certificate (the partition itself, not a bare boolean), counterexamples when the core is not sufficient, and a bound `contract_change_delta` callable reporting whether a newly reachable set of tuples still leaves a prior contract sufficient

before resynthesizing anything. A runtime pre-action gate is meant to consume this compiled contract and its certificate directly – gate schema and enforcement code are downstream engineering this paper does not implement.

9 Related Work and the Novelty Fence

Nine neighbouring literature clusters, each fetch-verified: what each established, and what this paper adds.

STPA and its descendants [16, 37, 29, 18, 27] establish a structured but human-driven analyst process: an engineer enumerates losses and hazards and writes safety constraints by hand, checked by expert review. None derive, in general, a machine-checked minimal property set for a runtime gate, or formalize soundness or minimality as machine-checkable claims over an enumerated model. This paper’s derivation is inspired by STPA’s loss-to-constraint direction of travel but replaces the analyst step with a deterministic, exhaustively-verified derivation.

ABAC policy mining [36, 19] starts from an existing lower-level policy plus attribute data and reconstructs which attributes already participate. This paper runs the derivation in the opposite direction, from a declared loss model forward to the minimal property set a new gate must observe, with a machine-checked soundness and minimality guarantee that mining, in general, has no ground-truth policy to verify against and so cannot provide.

Policy-language completeness [9, 10] establishes what a policy combination language can express once the participating attributes and base decisions are already fixed; neither asks which attributes must be observed in the first place. This paper contributes exactly the question both assume already answered.

Non-interference [12] is a semantic criterion for whether one party’s actions can affect what another observes – a check of dependence between two fixed parties, in general neither a derivation procedure nor a minimality guarantee. Definition 1 borrows the underlying comparison but turns it into a derivation swept over every candidate property against every loss predicate, with soundness and minimality verified exhaustively.

Counterfactual fairness [15] is structurally the same comparison Definition 1 uses, applied once, to a single pre-chosen sensitive attribute. This paper generalizes the comparison to every candidate property against a declared loss model and adds an exhaustive, machine-checked minimality result that, in general, the counterfactual-fairness literature neither claims nor checks.

Shield synthesis [5] synthesizes a runtime monitor correcting violating outputs over a system’s already-declared interface signals. This paper solves the strictly prior problem, in general, with a machine-checked minimality guarantee, upstream of the corrective strategy shield synthesis solves for.

Runtime enforcement and edit automata [33, 17] characterize and extend what a monitor may do to an already-fixed target-action alphabet, never which properties must be part of that alphabet in the first place – the antecedent question this paper answers in general, with a minimality guarantee neither work needs for its own narrower question.

Controller synthesis [28, 26] presupposes the plant’s or module’s own observable/controllable alphabet and synthesizes a control law within it. In general, the classical minimality result here is about the supervisor’s behaviour given that alphabet, not the alphabet itself; this paper derives the alphabet a controller must observe, before any supervisor or reactive module is synthesized over it.

Capability systems [11] establish the capability as an unforgeable reference carrying authority – *how* authority, once granted, is represented and delegated, not which conditions must be checked before it is minted. This artifact’s own execution-grant mechanism is engineering informed by this lineage’s modern descendants [3, 13, 4], not a novelty claim in its own right.

The fence, stated once. In general, none of the nine clusters above derive, from a declared loss model, a machine-checked minimal property set for a runtime authority gate, with soundness and minimality verified exhaustively over an enumerated model and certificates a downstream system consumes directly. This paper’s contribution sits upstream of all nine, answering a question each of them assumes already settled.

10 Limitations

- **Declared loss-model completeness** is assumed, not verified: a declared model missing a real hazard still produces a certified core or reduct *for the declared model*, silently uninformative about the missing one.
- **Reachability-model validity**: every result above is exact *given* its own declared reachable set, transcribed from its own registration, not measured from a live deployment.
- **Partial observability** is not modeled: every synthesis backend assumes the candidate properties it is given are the ones a gate *could* observe.
- **Temporal and probabilistic losses** are out of scope: every loss predicate here is a boolean function of one reachable tuple.
- **External validation**: the reproduction packet is this artifact’s own attempt to make independent reproduction possible; per its own eight-point standard, it is not itself independent evidence until someone who did not build this artifact runs it and reports back (no reproduction report filed as of this draft).
- **Families hard for exhaustive enumeration are not automatically hard for the solvers** synthesizing over their own discernibility family: Section 6’s own v5.3 families are registered-infeasible to enumerate and solve in well under a second regardless.
- **Reduct multiplicity in the Section 4 large domain (CH-C1) is a lower bound**, not an exhaustive count: blocking-clause enumeration capped at five found five distinct minimum-cardinality contracts; whether more exist above the cap is open.

11 Corrections and Historical Foundation

Append-only: nothing below is retracted or reworded; each correction is recorded alongside its original claim.

The v1 singleton-sufficiency overclaim (corrected v0.3). The original Proposition 1 asserted that observing exactly P^* lets a gate always compute M ’s true verdict on any executable-reachable tuple – conflating individual indispensability with joint sufficiency. A commissioned external, AI-assisted research review identified the mischaracterization; per this project’s own discipline the finding was not applied directly – it was adjudicated against this artifact’s own definitions, and Negative Proposition N’s counterexample was re-derived from first principles. Proposition 1 is superseded by Proposition 1’ (Section 3), not deleted.

The v5.0 degenerate scaling benchmark (disclosed v5.1). Section 6’s own exploratory benchmark scaled candidate-property count while holding the reachable set fixed at six tuples – a valid answer to the question it was built for, but one where the added noise properties cost the solver nothing beyond one boolean variable each. Relabelled `exploratory_v5_0` from v5.1 forward, superseded as the primary scaling claim, kept and cited.

The entangled v0.3 experiment arms and their null delta (found and corrected v0.4). Section 7’s own budget/ledger-sharing defect, found by this paper’s own code inspection, registered two-sided before any fix was written: isolating the three experiment arms’ state

produced a result byte-identical to the prior shared-state measurement – **not supported**, with the mechanism explaining why rather than left unexplained.

The two commissioned external review rounds. Round one produced the core-versus-reduct correction above. Round two produced the broadened contribution this paper’s own front matter names – the code/cloud flagship promoted to the empirical centre, packaging and CI-smoke-test gates, symbolic scaling and AuthorityBench framing, and the large non-planted domain this draft adds. Neither round’s finding was ever applied as a direct patch: every finding this paper’s own results reflect was independently re-derived and machine-checked against this artifact’s own definitions and data before being accepted.

Where the full historical procurement paper lives. Versions 0.1 through 0.5 are each frozen at their own commit, unedited since, and linked from the companion repository’s own README.md History section – the complete v1-through-v4 Introduction, novelty fence, replication, Definitions 1–6, derivation procedure, grant mechanism, pair testing, empirical section, and their own Threats to validity, Limitations, and Conclusion are preserved there in full, not reproduced a second time in this consolidated manuscript.

12 Threats to Validity, Claims, and Proof Status

Threats to validity, written adversarially. First, every “realistic” domain in Section 4 is still a declared model, not a live deployment – a domain built by the same author to be plausible is not independent evidence that real deployments share its structure. Second, CH-C1’s own multiplicity count is a lower bound capped at five by construction – a reader could reasonably suspect the true count is far larger, which would weaken, not strengthen, any claim resting on “few” alternatives. Third, CH-C2’s cost tie could be read as this paper quietly avoiding a more impressive result – the tie is reported at face value, with the mechanism that produces it stated explicitly. Fourth, AuthorityBench’s mining comparison is inconclusive by its own registered rule; it is reported because the registration committed to reporting whatever was measured, not only a clean win.

This paper claims	This paper does not claim
On two independently-built, non-planted domains, the core is not always a reduct (CH-B1, CH-C1).	That the core is never a reduct – v2’s own worked instance (Section 3) is a real counterexample to that stronger claim.
On one of those two domains, declared cost strictly separates the minimum-cardinality alternatives (CH-B2).	That declared cost always separates them – CH-C2, on the other domain, is a genuine tie.
Exhaustive reduct enumeration is registered-infeasible on the Section 6 hardness families and the Section 4 large domain, and SAT/MaxSAT synthesis solves them regardless.	That every hard-to-enumerate instance is easy for these solvers, or that this artifact has found the general boundary between the two.
MaxSAT showed no measured cardinality advantage over plain SAT on the specific registered v5.3 families.	That MaxSAT never has a cardinality advantage over SAT in general.
The declared-only manual baseline is not exactly sufficient on any of AuthorityBench’s three registered domains.	That no declared-only policy could ever be sufficient – v2’s own core happens to be sufficient (Section 3).

This paper claims	This paper does not claim
The reproduction infrastructure is complete and checked against an eight-point standard.	That this artifact has been independently reproduced – that item is pending, checked directly against the issue tracker, not assumed.

Proof status. Every numbered formal claim carries a `PROOF-STATUS` tag in the companion repository’s own `appendix-a-proofs.md`: `machine-checked` (an executable checker module verifies the claim over an explicitly enumerated finite domain), `checked-scope-only` (the certified scope is narrower than the general prose, stated exactly), or `pending-human-review` (asserted, not yet machine-verified) – `proven` is never written. Every Section 4 hypothesis (CH-B1, CH-B2, CH-C1, CH-C2) carries the same discipline inline, naming its own checker and enumerated domain rather than asserting a bare result.

Acknowledgements. Drafting, engineering, formal derivation, and citation verification were AI-assisted (Claude); the author is solely responsible for all claims.

References

- [1] Cloud Security Alliance. Cloud Controls Matrix (CCM) v4.1 – Infrastructure & Virtualization Security (IVS) domain, 2026. Two independently-worded WebSearch queries (2026-09-07/08) both confirming the Infrastructure & Virtualization Security (IVS) domain’s existence and its tenant-isolation/multi-tenancy-segmentation controls (one earlier aggregated result paraphrased the domain name with swapped word order; the canonical name confirmed directly against the official CSA site is ‘Infrastructure & Virtualization Security (IVS)’); direct WebFetch of the official CSA research page confirmed the current version (4.1, released January 2026, no newer major version found) and its full 17-domain list including IVS. Cited (`prereg/v4-realistic-domain.md`, `losses_v4.cross_tenant_action`) as the multi-tenant isolation source an action outside the acting role’s declared tenant scope crosses.
- [2] Gaston Besanson. One Gate Is Not Enough: Composing Stateful Pre-Action Controls for Agentic AI, 2026. WebFetch of <https://arxiv.org/abs/2608.18360>, 2026-08-31 (title/author/date confirmed); independently cross-confirmed by direct reading of the pinned `sarc-suite-one-pass` sibling at commit 782261e – its own `README.md`, `RESEARCH-GUIDE.md`, and `paper-tex/parity-report.json` all carry the identical title – this is paper 4 of the SARC series, the imported baseline this paper builds on and cites throughout.
- [3] Arnar Birgisson, Joe Gibbs Politz, Úlfar Erlingsson, Ankur Taly, Michael Vrabie, and Mark Lentczner. Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud. In *NDSS Symposium 2014*, 2014. WebSearch AND a direct WebFetch of the NDSS Symposium’s own official programme page (ndss-symposium.org), 2026-09-06: both independently confirm the exact title, the full six-author order, and the NDSS 2014 venue. Cited (`paper5 draft v0.3`, Section 6) as capability-system prior art for the execution grant, repositioning grant binding as engineering informed by established patterns rather than a novelty claim, per the external research review’s own comparison (`review-secondary/external-research-review-2026-09-06.pdf`, question 26).
- [4] Eclipse Biscuit. Biscuit, a bearer token with offline attenuation and decentralized verification, 2026. WebSearch AND direct WebFetch of both the raw `SPECIFICATIONS.md` document (`raw.githubusercontent.com/eclipse-biscuit/biscuit/main/SPECIFICATIONS.md`)

and the project’s GitHub repository, 2026-09-06: both confirm the exact document title and that the project originated at Clever Cloud and is now maintained under the Eclipse Foundation (eclipse-biscuit) – a living specification with no single fixed publication year; the year field records this citation’s verification/access date. Cited (paper5 draft v0.3, Section 6) as capability-system prior art for the execution grant, per the external research review’s own comparison (review-secondary/external-research-review-2026-09-06.pdf, question 26).

- [5] Roderick Bloem, Bettina Konighofer, Robert Konighofer, and Chao Wang. Shield Synthesis: Runtime Enforcement for Reactive Systems. In *TACAS 2015 (21st International Conference on Tools and Algorithms for the Construction and Analysis of Systems)*, 2015. Direct WebFetch of <https://tugraz.elsevierpure.com/en/publications/shield-synthesis-runtime-enforcement-for-reactive-systems>, 2026-09-08 (after the original graz.elsevierpure.com URL 301-redirected there): confirmed exact title, full four-author order, TACAS 2015, LNCS volume 9035, page range 533-548, and DOI directly from the TU Graz research portal record. Cited in NOVELTY.md’s Eighth amendment (prereg/v6.1-authoritybench-amendment.md, Step 5) as the shield-synthesis literature cluster: constructs a corrective law over an already-fixed signal interface, not a derivation of the interface itself.
- [6] MITRE Corporation. CWE-798: Use of Hard-coded Credentials, 2026. Two independently-worded WebSearch queries (2026-09-07/08) both confirming the exact title against the official mitre.org URL; direct WebFetch of cwe.mitre.org/data/definitions/798.html confirmed the exact title verbatim and current CWE list version (4.20, the verification-access year recorded here, not a claimed original-creation year, which was not independently confirmed from a primary source). Cited (prereg/v4-realistic-domain.md, losses_v4.secret_exposure) as the canonical weakness class the predicate detects an exposure path for.
- [7] MITRE Corporation. MITRE ATT&CK Tactic TA0004: Privilege Escalation, 2026. Two independently-worded WebSearch queries (2026-09-07/08) both confirming tactic ID (TA0004), exact name, and Enterprise domain; direct WebFetch of the live official attack.mitre.org page confirmed the same. Cited (prereg/v4-realistic-domain.md, losses_v4.privilege_escalation) as the taxonomy source for a role without declared grant authority attempting to grant one anyway.
- [8] MITRE Corporation. MITRE ATT&CK Technique T1485: Data Destruction, 2026. Two independently-worded WebSearch queries (2026-09-07/08) both confirming technique ID (T1485), exact name, and parent tactic (Impact, TA0040); direct WebFetch of the live official attack.mitre.org page confirmed the same plus one sub-technique (T1485.001). Cited (prereg/v4-realistic-domain.md, losses_v4.destructive_action_without_recovery_path) as the failure mode a destructive operation with no declared remediation operator exists to catch.
- [9] Jason Crampton and Charles Morisset. PTaCL: A Language for Attribute-Based Access Control in Open Systems. In *POST 2012 (1st International Conference on Principles of Security and Trust)*, 2012. WebSearch, 2026-08-31: title/authors/venue/DOI corroborated across Royal Holloway’s PURE research portal, Semantic Scholar, and Springer’s own chapter page.
- [10] Jason Crampton and Conrad Williams. On Completeness in Languages for Attribute-Based Access Control. In *SACMAT 2016 (21st ACM Symposium on Access Control Models and Technologies)*, 2016. WebFetch of <https://pure.royalholloway.ac.uk/en/publications/>

- [on-completeness-in-languages-for-attribute-based-access-control](#), 2026-08-31: confirmed exact title, authors, venue, and year directly from Royal Holloway’s research portal record.
- [11] Jack B. Dennis and Earl C. Van Horn. Programming semantics for multiprogrammed computations. *Communications of the ACM*, 1966. Direct WebFetch of https://www.princeton.edu/~rblee/ELE572Papers/Fall04Readings/ProgramSemantics_DennisvanHorn.pdf, 2026-09-08, read via page-image rendering (text extraction failed, image rendering succeeded): title ‘Programming Semantics for Multiprogrammed Computations’, authors ‘Jack B. Dennis and Earl C. Van Horn, Massachusetts Institute of Technology’, and the exact venue line ‘Volume 9 / Number 3 / March, 1966 – Communications of the ACM’, page 143, all visible directly on the rendered page. Cited in NOVELTY.md’s Eighth amendment as the foundational capability-systems citation: the original C-list/capability primitive for representing and propagating authority once granted, not a derivation of which conditions must be checked before granting it – the common ancestor of this project’s own already-cited macaroons-ndss-2014/ucan-specification/biscuit-specification (cited elsewhere for the execution grant’s own representation, not for this distinction).
 - [12] Joseph A. Goguen and José Meseguer. Security Policies and Security Models. In *3rd IEEE Symposium on Security and Privacy*, 1982. WebFetch of <https://dblp.org/db/conf/sp/sp1982.html>, 2026-08-31: confirmed exact title, author order, venue, year, pages, and DOI directly from the dblp proceedings listing.
 - [13] UCAN Working Group. User Controlled Authorization Network (UCAN) Specification, 2026. WebSearch AND a direct WebFetch of <https://ucan.xyz/specification/>, 2026-09-06: both confirm the exact title and that this is a community-maintained living specification (source at github.com/ucan-wg/spec), not a dated academic paper – no single fixed publication year is stated in the document itself; the year field records this citation’s verification/access date, not a claimed publication date. Cited (paper5 draft v0.3, Section 6) as capability-system prior art for the execution grant, per the external research review’s own comparison ([review-secondary/external-research-review-2026-09-06.pdf](#), question 26).
 - [14] Moona Intelligence. SARC Shows Why Remediated Agent Actions Need to Be Re-Evaluated, 2026. WebFetch of <https://moona.ozlunara.com/intelligence/sarc-suite-remediate-regate-authority-coverage-boundary>, 2026-08-31, four separate targeted fetches, cross-checking specific quotes for exact wording (one earlier candidate quote about registering ‘sku, agent_id, day, or a grant identifier as predicates’ could NOT be re-found on a third targeted search and is treated as unverified/likely reconstructed by the fetch tool’s summarizer – NOT used anywhere in this paper). Two quotes used in the paper were each independently reproduced, word-for-word, across two separate fetch calls with different prompts: the ‘I want to be plain about the framing here...’ sentence, and finding A7’s ‘authorization identifier, an approval identifier, a nonce, or any consume on use mechanism’ sentence. The report’s own ‘215 passing tests’ (207 original + 8 new) is independently consistent with the already-committed REPLICATIONS.md’s ‘207 tests’ / ‘eight additional adversarial authority tests’, corroborating this is the correct, genuine report rather than a fabricated page. Publication date (28 August 2026) and the mirror URL (published under the organisation’s then-name, Belay Intelligence) per REPLICATIONS.md, already committed in the pinned sarc-suite-one-pass sibling and not independently re-verified here. UPDATE 2026-09-04 (draft v0.1.1): a third quote, from the report’s ‘My take’ closing section (‘a re-evaluation mechanism is only as complete as the policy it re-evaluates, and a policy’s completeness is a property of what it was configured to read, not of the architecture that calls it’), independently reproduced word-for-word across two

separate fetch calls with different prompts, the second returning the full surrounding paragraph (which independently corroborates the same four coverage-boundary categories – resource identity, actor-specific identity, time, execution-specific grant binding – already cited in this entry from the earlier fetches), same cross-check bar as the two quotes above.

- [15] Matt J. Kusner, Joshua Loftus, Chris Russell, and Ricardo Silva. Counterfactual Fairness. In *Advances in Neural Information Processing Systems 30 (NeurIPS 2017)*, 2017. WebFetch of https://proceedings.neurips.cc/paper_files/paper/2017/hash/a486cd07e4ac3d270571622f4f316ec5-Abstract.html, 2026-08-31: confirmed exact title, full author order, and year directly from the NeurIPS proceedings page.
- [16] Nancy G. Leveson and John P. Thomas. STPA Handbook, 2018. WebSearch, 2026-08-31: two independent search snippets quote the document’s own title-page text (‘NANCY G. LEVESON JOHN P. THOMAS MARCH 2018’) from the flighttestsafety.org mirror; MIT PSAS canonical URL (psas.scripts.mit.edu) located and recorded as the citation url. Direct WebFetch of the PDF returned only undecoded binary/stream data, so verification rests on the indexed title-page text, not a rendered fetch – flagged for a human to re-confirm by opening the PDF directly.
- [17] Jay Ligatti, Lujo Bauer, and David Walker. Edit automata: enforcement mechanisms for run-time security policies. *International Journal of Information Security*, 2005. Direct WebFetch of <https://collaborate.princeton.edu/en/publications/edit-automata-enforcement-mechanisms-for-run-time-security-polic/>, 2026-09-08: confirmed exact title, full three-author order, journal name, volume/issue (4(1-2)), page range (2-16), February 2005, and DOI directly from Princeton’s own research-portal record (the Springer chapter page itself 303-redirected to an access-gated IdP login and could not be fetched directly). Cited in NOVELTY.md’s Eighth amendment alongside Schneider 2000 as the edit-automata half of the runtime-enforcement cluster: extends the monitor’s corrective repertoire (insert/suppress, not just truncate) over the same already-fixed action alphabet Schneider fixes, without deriving that alphabet.
- [18] Simon Mylius. Systematic Hazard Analysis for Frontier AI using STPA, 2025. WebFetch of <https://arxiv.org/abs/2506.01782>, 2026-08-31: confirmed exact title, sole authorship by Simon Mylius, and June 2025 submission date.
- [19] Mohammad Nur Nobil, Maanak Gupta, Lopamudra Praharaj, Mahmoud Abdelsalam, Ram Krishnan, and Ravi Sandhu. Machine Learning in Access Control: A Taxonomy and Survey, 2022. WebFetch of <https://arxiv.org/abs/2207.01739>, 2026-08-31: confirmed exact title, full author order, 2022 submission, and that policy mining (including ABAC) is an explicit surveyed category; used as the brief’s ‘one recent survey’ of ABAC policy mining, since it is the most recent taxonomy-level survey found covering that problem (see NOVELTY.md for why the 2017 Servos & Osborn ABAC survey was not used instead: broader scope, not recent).
- [20] National Institute of Standards and Technology. Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5) – control AC-3, Access Enforcement, 2020. Two independently-worded WebSearch queries (2026-09-10) both returning the identical control ID/title/family (Access Control) and definition across independent mirrors (csf.tools, UpGuard, STIG Viewer, GRC Academy) that publish NIST’s own OSCAL/JSON catalog verbatim – ‘AC-3 requires organizations to enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies’, explicitly distinguished from AC-2 (who gets access) and AC-6 (how much access). Same parent document as the already-verified nist-sp-800-53-cm3 entry; NIST’s own interactive control browser is a JS single-page

app not directly text-fetchable, so the control text itself rests on the third-party mirrors, matching that entry’s own flagged caveat. Cited (prereg/v8-large-realistic-domain.md, losses_v8.unauthorized_mutation) alongside RBAC96 as the access-mediation source a mutating operation must be checked against.

- [21] National Institute of Standards and Technology. Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5) – control AC-6, Least Privilege, 2020. Two independently-worded WebSearch queries (2026-09-10) both returning the identical control ID/title/family (Access Control) and definition across independent mirrors (UpGuard, CSF Tools, GRC Academy) – ‘requiring organizations to grant users and processes only the minimum access necessary to perform assigned tasks... applies to all system identities, including human users, automated processes, and service accounts’, both searches explicitly confirming the automated-process scope. Same parent document as the already-verified nist-sp-800-53-cm3/nist-sp-800-53-ac3 entries, same third-party-mirror caveat. Cited (prereg/v8-large-realistic-domain.md, losses_v8.automated_actor_manual_only_operation) as the least-privilege source for why a fully-automated principal performing a role grant is flagged regardless of its own declared operation ceiling.
- [22] National Institute of Standards and Technology. Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5) – control CM-3, Configuration Change Control, 2020. Two independently-worded WebSearch queries (2026-09-07/08) both returning the identical control ID/title/family (Configuration Management) across independent mirrors (csf.tools, UpGuard, GRC Academy, GSA) that publish NIST’s own OSCAL/JSON catalog verbatim; direct WebFetch of the official NIST publication landing page confirmed the parent document’s exact title and revision (5, original 2020, most recently updated as Release 5.2.0, 27 August 2025 per NIST’s own change-summary). NIST’s own interactive control browser is a JS single-page app not directly text-fetchable, so the control text itself rests on the third-party mirrors, not a direct NIST plain-text fetch – flagged for the author’s own spot-check. Cited (prereg/v4-realistic-domain.md, losses_v4.production_deployment_without_approval) as the change-management source a production deployment requires a recorded approval before it applies.
- [23] European Parliament and Council of the European Union. Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications), 2002. WebSearch, 2026-09-08: official EUR-Lex location and Official Journal citation (L 201, 31/07/2002, pp. 37-47) confirmed; Article 5(1)’s confidentiality-of-communications text (‘Member States shall ensure the confidentiality of communications... shall prohibit listening, tapping, storage or other kinds of interception or surveillance of communications... without the consent of the users concerned’) retrieved directly. Cited in prereg/v6.1-authoritybench-amendment.md’s ‘unconfidential_channel’ loss predicate.
- [24] European Parliament and Council of the European Union. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), 2016. WebFetch of <https://eur-lex.europa.eu/eli/reg/2016/679/oj>, 2026-09-08 (title, regulation number, adoption date, and Official Journal citation confirmed directly from the official EU legislative portal); Article 6(1) (lawful bases), Article 9(1)/9(2) (special category data, ten enumerated exceptions – legitimate interest confirmed NOT among them

via a second direct fetch of gdpr-info.eu/art-9-gdpr/, 2026-09-08), Article 17 (erasure), Article 44 (general principle for transfers), and Article 5(1)(e) (storage limitation) are each cited by name in `prereg/v6.1-authoritybench-amendment.md`'s own loss-predicate table, not paraphrased from memory.

- [25] Zdzisław Pawlak. Rough Sets. *International Journal of Computer and Information Sciences*, 1982. Direct Read of the paper's own PDF first page (fetched via a WebSearch-located mirror, [sci2s.ugr.es/keel/dataset/includes/catImbFiles/1982 - Pawlak.pdf](https://sci2s.ugr.es/keel/dataset/includes/catImbFiles/1982%20-%20Pawlak.pdf), 2026-09-06): title 'Rough Sets', author 'Zdzisław Pawlak', header line 'International Journal of Computer and Information Sciences, Vol. 11, No. 5, 1982', and page number 341 all visible directly on the rendered title page, not merely an indexed snippet. DOI cross-confirmed via WebSearch (scirp.org's reference listing; Springer's own article page at link.springer.com/article/10.1007/BF01001956). Cited (`prereg/v3-core-reduct-correction.md`; `paper5 draft v0.3`) as the foundational source for the core/reduct distinction Proposition 1' corrects to.
- [26] Amir Pnueli and Roni Rosner. On the synthesis of a reactive module. In *POPL 1989 (16th ACM Symposium on Principles of Programming Languages)*, 1989. Two independently-worded WebSearch queries (2026-09-08) both returning the identical title, both authors, POPL 1989 venue, page range 179-190, and DOI 10.1145/75277.75293 (the ACM DL page itself returned 403 Forbidden to a direct WebFetch); both searches also independently distinguished this paper from the authors' related but distinct 'On the synthesis of an asynchronous reactive module' (ICALP 1989), confirming no conflation between the two. Cited in NOVELTY.md's Eighth amendment as the temporal-logic/reactive-synthesis half of the controller-synthesis cluster: constructs a winning strategy over already-declared input/output signals, not a derivation of which signals must be declared.
- [27] Yi Qi, Yi Dong, Siddhartha Khastgir, Paul Jennings, Xingyu Zhao, and Xiaowei Huang. STPA for Learning-Enabled Systems: A Survey and A New Practice, 2023. WebFetch of <https://arxiv.org/abs/2302.10588>, 2026-08-31: confirmed exact title, full author order, 2023, and that the abstract itself introduces DeepSTPA as this paper's extension of STPA's control-loop model to the ML development lifecycle.
- [28] P. J. Ramadge and W. M. Wonham. Supervisory Control of a Class of Discrete Event Processes. *SIAM Journal on Control and Optimization*, 1987. Direct WebFetch of <https://collaborate.princeton.edu/en/publications/supervisory-control-of-a-class-of-discrete-event-processes/>, 2026-09-08: confirmed exact title, both authors, journal name, volume/issue/pages (25(1), 206-230), 1987, and DOI directly from Princeton's own research-portal record (the ACM DL page itself returned 403 Forbidden). Cited in NOVELTY.md's Eighth amendment as the discrete-event/supervisory-control half of the controller-synthesis cluster: synthesizes a maximally permissive supervisor over an already-fixed plant event alphabet, not a derivation of the alphabet itself.
- [29] Shalaleh Rismeni, Roel Dobbe, and AJung Moon. From Silos to Systems: Process-Oriented Hazard Analysis for AI Systems, 2024. WebFetch of <https://arxiv.org/abs/2410.22526>, 2026-08-31: confirmed exact title, full author order, 2024 submission, and that this is the paper defining the PHASE guideline (abstract states it directly).
- [30] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. Zero Trust Architecture (NIST Special Publication 800-207), 2020. Direct WebFetch of <https://csrc.nist.gov/pubs/sp/800/207/final>, 2026-09-10: title 'Zero Trust Architecture', publication number SP 800-207, authors Scott Rose (NIST)/Oliver Borchert (NIST)/Stu

Mitchell (Stu2Labs)/Sean Connelly (DHS), publication date August 2020, all confirmed directly from the official NIST publication page – which also confirms the exact claim this citation backs, quoting the document’s own abstract: zero trust ‘assumes there is no implicit trust granted to assets or user accounts based solely on their physical or network location (i.e., local area networks versus the internet)’, and ‘the network location is no longer seen as the prime component to the security posture of the resource’. Cross-checked against a separate WebSearch query returning the same title/authors/date from NIST’s own news release. Cited (prereg/v8-large-realistic-domain.md, losses_v8.external_network_zone_for_sensitive_data) as the source for network location never itself being a trust signal.

- [31] Arto Salomaa. On essential variables of functions, especially in the algebra of logic, 1963. WebSearch, 2026-09-08: exact citation (‘A. Salomaa, On essential variables of functions, especially in the algebra of logic, Ann. Acad. Sci. Fenn. Ser. A I. Math. 339 (1963) 3-11’) confirmed directly via WebFetch of arxiv.org/html/math/0701332 (Couceiro, M. and Lehtonen, E., ‘On the effect of variable identification on the essential arity of functions’), item [11] of its own reference list – Salomaa’s 1963 paper itself predates arXiv and has no freely-accessible copy located; the arXiv URL recorded here (math/0701332) is the freely-available paper that cites it and, fetch-confirmed, states the identical mathematical definition of an essential variable this project relies on: ‘there are elements $a_1, \dots, a_n, b$ such that $f(a_1, \dots, a_i, \dots, a_n) \neq f(a_1, \dots, a_{i-1}, b, a_{i+1}, \dots, a_n)$ ’ – term for term Definition 1 (participation.py), independently sourced from switching/Boolean-function theory rather than rough-set theory (Pawlak 1982; Skowron and Rauszer 1992, already cited). Used in prereg/v6.1-authoritybench-amendment.md’s ‘essential-variable analysis’ baseline.
- [32] Ravi S. Sandhu, Edward J. Coyne, Hal L. Feinstein, and Charles E. Youman. Role-Based Access Control Models. *IEEE Computer*, 1996. Two independently-worded WebSearch queries (2026-09-07/08), both returning the identical venue/volume/issue/pages/authors, one also returning ADS bibcode 1996Compr..29b..38S corroborating year/vol/issue/page/author-initial; direct WebFetch of the NIST-hosted author PDF mirror (csrc.nist.gov/csrc/media/projects/role-based-access-control/documents/sandhu96.pdf) confirmed the exact title and full four-author list; the DOI resolves live to IEEE Xplore. Cited (prereg/v4-realistic-domain.md, losses_v4.unauthorised_mutation) as the RBAC source a mutating operation must be mediated against the acting role’s own declared authority.
- [33] Fred B. Schneider. Enforceable Security Policies. *ACM Transactions on Information and System Security (TISSEC)*, 2000. Direct WebFetch of <https://www.cs.cornell.edu/fbs/publications/EnfSecPols.pdf>, 2026-09-08, read via page-image rendering (text extraction failed, image rendering succeeded): title ‘Enforceable Security Policies’, author ‘FRED B. SCHNEIDER, Cornell University’, and the exact venue line ‘ACM Transactions on Information and System Security, Vol. 3, No. 1, February 2000, Pages 30-50’ all visible directly on the rendered first page, along with the paper’s own abstract stating it gives ‘a precise characterization... for the class of security policies enforceable with mechanisms that work by monitoring system execution’ (Execution Monitoring, EM). Cited in NOVELTY.md’s Eighth amendment as the foundational runtime-enforcement/EM citation: characterizes what a monitor can enforce over an already-fixed action alphabet, not which properties belong in that alphabet.
- [34] Andrzej Skowron and Cecylia Rauszer. The Discernibility Matrices and Functions in Information Systems. In *Intelligent Decision Support: Handbook of Applications and Advances of the Rough Sets Theory*. 1992. WebSearch, 2026-09-06, two independently-worded

queries both corroborating the exact title, both authors, venue (Intelligent Decision Support, ed. Słowiński, Springer/Kluwer Dordrecht), year 1992, and page range 331-362, across Springer’s own chapter listing and Semantic Scholar’s indexed record. Cited (prereg/v3-core-reduct-correction.md) as the discernibility-matrix source reduct.py’s exact reduct enumeration is positioned against.

- [35] Zhongyuan Xu and Scott D. Stoller. ABAC-Mining: implementation and case-study data for "Mining Attribute-Based Access Control Policies" (case-studies/healthcare.abac), 2014. The paper’s own page 7 text ('All of the code and data is available at <http://www.cs.sunysb.edu/~stoller/>') was followed 2026-09-08; that address now 503s (WebFetch), so the current homepage was located instead (WebSearch, then WebFetch of <https://www3.cs.stonybrook.edu/~stoller/>), whose 'Software' page (software/index.html) links ABAC-Mining.zip with the description 'an implementation of the policy mining algorithms described in our 2015 IEEE TDSC paper.' Downloaded directly via curl, 2026-09-08: 32,482,151 bytes, sha256 5da1e61877585720a3276605517117a74546577f47fb82ecd026e0f7a47fd106. Its ABACMining/case-studies/healthcare.abac (sha256 4ce5c62c122a4b0d8f30da222ac8effd9a665d6fe9ff11fe3a799b3d2f68f429) is the paper’s own hand-authored 'Health Care Sample Policy' (Section 5’s evaluation); GPLv3 (COPYING in the same archive) – the code is not vendored into this Apache-2.0 repository, only the attribute-value and rule facts are transcribed by hand into fresh Python (xu_stoller_validation.py), the same discipline this project already applies to cited legal text. Cross-checked directly against the paper’s own PDF (fetched from <https://www3.cs.stonybrook.edu/~stoller/papers/abac-mining-TDSC.pdf>, read via page-image rendering since text extraction failed on this file): Fig. 5’s health care row (page 8: |Rules|=9, |A_u|=6, |A_r|=7, |Op|=3, |U|=21, |R|=16, |UP|=51, average per-rule coverage 6.7) and Section 5.1’s prose (page 7: with no attribute declared unremovable, the mined policy drops the redundant 'type=HRitem' RAE conjunct from exactly four rules, otherwise identical to the original – i.e. their own algorithm mines 9 rules on this input). 'xu_stoller_validation.py's transcription independently reproduces |UP|=51 exactly (not assumed, computed) before any mining code runs against it – prereg/v6.1-authoritybench-amendment.md’s own 'ABAC policy mining, reimplemented from Xu and Stoller' baseline validation gate.
- [36] Zhongyuan Xu and Scott D. Stoller. Mining Attribute-Based Access Control Policies. *IEEE Transactions on Dependable and Secure Computing*, 2015. WebSearch, 2026-08-31: title/authors/venue/volume/issue/pages/DOI corroborated across the authors’ own Stony Brook policy-mining page (www3.cs.stonybrook.edu/~stoller/policy-mining/) and independent bibliographic indexes; distinguished from the authors’ earlier 2013/2014 conference-track pieces (CEWIT 2013, DBSec 2014) on the same problem, per the task brief’s '2014-2015' framing. UPDATE 2026-09-08 (prereg/v6-authority-bench.md, Milestone E2): WebFetch of <https://arxiv.org/abs/1306.2401>, the freely-available preprint of this same work (per the Stony Brook page’s own listing: 'June 2013, updated August 2014' – the earlier-venue draft of the eventual TDSC 2015 journal form already verified above, not a different paper), returned the full abstract, quoted directly in prereg/v6-authority-bench.md: 'Our algorithm iterates over tuples in the given user-permission relation, uses selected tuples as seeds for constructing candidate rules, and attempts to generalize each candidate rule to cover additional tuples in the user-permission relation by replacing conjuncts in attribute expressions with constraints. Our algorithm attempts to improve the policy by merging and simplifying candidate rules, and then it selects the highest-quality candidate rules for inclusion in the generated policy.' This is the only textual claim about the algorithm’s own mechanics this project relies on; prereg/v6-authority-bench.md’s own reimplementation is registered as explicitly scoped to what this quoted abstract describes, not to the paper’s full method.

- [37] William Young and Nancy G. Leveson. An Integrated Approach to Safety and Security Based on Systems Theory. *Communications of the ACM*, 2014. WebSearch, 2026-08-31: title/authors/venue/year/DOI corroborated across cacm.acm.org, Semantic Scholar, and dblp-indexed snippets; this CACM piece is the canonical citation for STPA-Sec, distinct from the earlier informal 2013 workshop write-up.